

Centenary Baptist Church CMS

Phase 6 — Step 12: Final Production Verification & Security Audit

Generated: 29 September 2026 | Project: centenary-baptist-church | Auditor: Antigravity IDE

Security: PASS

Database: PASS

Backend/API: PASS

Frontend: PASS

CSP: WARNING

SEO: WARNING

3 Manual Actions Required

PENDING MANUAL ACTION — Donation QR Code Migration

The `donation_config` Supabase table exists and the backend code correctly reads from it, but the existing QR code has not yet been migrated from local storage to Supabase Storage. You must re-upload the QR code image via **Admin Dashboard → Donations** to complete the migration. Until then, the public Give page will display no QR code.

1. Authentication & Authorization — PASS

Route	Method	Protection	Result
/api/events	GET	Public	200 ✓
/api/sermons	GET	Public	200 ✓
/api/ministries	GET	Public	200 ✓
/api/campus	GET	Public	200 ✓
/api/gallery	GET	Public	200 ✓
/api/leadership	GET	Public	200 ✓
/api/donations/config	GET	Public	200 ✓
/api/admin-users	GET	requireAuth + requireSuperAdmin	401 ✓
/api/audit-logs	GET	requireAuth + requireSuperAdmin	401 ✓
/api/donations	GET	requireAuth	401 ✓
/api/contact	GET	requireAuth	401 ✓
/api/visitor	GET	requireAuth	401 ✓
All CMS POST/PUT/DELETE	Mutation	requireAuth	PASS (static)
/api/settings PUT/PATCH	Mutation	requireAuth + requireSuperAdmin	PASS (static)
/api/donations/config POST	Upload	requireAuth	PASS (static)
/api/upload POST	Upload	requireAuth	PASS (static)
/api/media/:filename DELETE	Delete	requireAuth	PASS (static)

2. Super Admin Security — PASS

Check	Result
/api/admin-users/setup-super-admin endpoint	NOT FOUND — removed ✓
Hardcoded credentials search (JOHN@123)	0 results ✓
requireSuperAdmin reads user_metadata.role	PASS ✓
SUPABASE_SERVICE_KEY in source (env ref only)	PASS ✓
SMTP_PASSWORD in source	0 results ✓

3. Supabase RLS — PASS (Static Verification)

Table	RLS Enabled	Read Policy	Write Protection
events	✓	Public anon read	Backend service key only
sermons	✓	Public anon read	Backend service key only
ministries	✓	Public anon read	Backend service key only
campus	✓	Public anon read	Backend service key only
gallery	✓	Public anon read	Backend service key only
leadership	✓	Public anon read	Backend service key only
donations	✓	requireAuth	Backend service key only
contacts	✓	requireAuth	Backend service key only
visitors	✓	requireAuth	Backend service key only
audit_logs	✓	requireSuperAdmin	Backend service key only
site_settings	✓	Public read	requireSuperAdmin
donation_config	✓	Public read	authenticated only

4. Database Integrity — PASS

Check	Result
Primary keys (UUID gen_random_uuid())	PASS — all new tables use UUID
donation_config singleton constraint (UNIQUE INDEX ON (true))	PASS (migration-03)
updated_at columns	PASS (migration-01)
sort_order / order_index indexes	PASS (migration-04)
Leadership uses order_index, not sort_order	CONFIRMED & corrected in migration-04
All 3 migrations contain no DROP/TRUNCATE/DELETE	PASS

5. File Upload Security — PASS

Check	File	Result
Auth before upload processing	uploadRoutes.js	requireAuth before multer ✓
5MB file size limit	uploadRoutes.js, donationRoutes.js	PASS
Allowed MIME types (JPG/PNG/WebP)	All upload routes	PASS
crypto.randomUUID() safe naming	uploadRoutes.js, donationRoutes.js	PASS
memoryStorage() for donations	donationRoutes.js	PASS
No diskStorage runtime writes for QR	donationRoutes.js	PASS (removed)
Supabase Storage upload	uploadRoutes.js, donationRoutes.js	PASS
Path traversal prevention	No req.params in storage paths	PASS

6. Donation Configuration — WARNING

Check	Result
donation_config table exists	PASS (migration-03 executed)
Singleton constraint	PASS
RLS policies	PASS
POST /config routes to Supabase Storage	PASS (code)
GET /config reads from Supabase	PASS (code)
donationConfig.json removed from runtime	PASS (no JS references)
Existing QR migrated to Supabase Storage	⚠️ REQUIRES MANUAL ACTION
Backend restart loses QR	PASS — won't happen once QR is re-uploaded

Action Required

Log into Admin Dashboard → Donations → re-upload the QR code image. This writes the image to Supabase Storage and updates the donation_config row with the stable public URL.

7. Frontend API Configuration — PASS

Check	Result
localhost:3000 in src/	0 matches ✓
donationConfig.json in src/	0 matches ✓
SMTP_PASSWORD in src/	0 matches ✓
src/apiConfig.js uses VITE_API_BASE_URL '/api'	PASS
Vite proxy scoped to dev server block only	PASS
SUPABASE_SERVICE_KEY in dist/	0 matches ✓
localhost:3000 in dist/	0 matches ✓
SMTP_PASSWORD in dist/	0 matches ✓

8. CORS & Security Headers — PASS with WARNING

Check	Result
CORS not wildcard *	PASS — origin whitelist implemented
CORS_ORIGIN env-driven	PASS — reads from process.env.CORS_ORIGIN
Malicious origins rejected	PASS
Helmet enabled	PASS
X-Content-Type-Options	PASS (Helmet default)
X-Frame-Options	PASS (Helmet default)
Content Security Policy (CSP)	⚠ WARNING — disabled (contentSecurityPolicy: false)
crossOriginEmbedderPolicy	WARNING — disabled for Supabase/Maps
Production CORS_ORIGIN configured	⚠ REQUIRES MANUAL ACTION before deploy

9. API Functional Testing — PASS

Endpoint	Status	Paginated
GET /api/events?limit=10&page=1	200 ✓	PASS
GET /api/sermons?limit=10&page=1	200 ✓	PASS
GET /api/ministries?limit=10&page=1	200 ✓	PASS
GET /api/campus?limit=10&page=1	200 ✓	PASS
GET /api/gallery?limit=10&page=1	200 ✓	PASS
GET /api/leadership?limit=10&page=1	200 ✓	PASS
GET /api/donations/config	200 ✓	N/A
Hard limit enforcement (?limit=200)	Capped to 100 ✓	PASS

10. CMS → Database → Public Website Flow — PASS

Pipeline	Status
Events: CMS → Supabase → API → Frontend	PASS
Sermons: CMS → Supabase → API → Frontend	PASS
Ministries: CMS → Supabase → API → Frontend	PASS
Campus: CMS → Supabase → API → Frontend	PASS
Leadership: CMS → Supabase → API → Frontend	PASS
Gallery: CMS → Supabase → API → Frontend	PASS
Donation Config: CMS → Supabase → API → Frontend	⚠ Pending manual QR re-upload

11. Homepage Verification — PASS

Check	Result
Events hydrated from API (/api/events)	PASS — main.js fetches on DOMContentLoaded
Sermons hydrated from API (/api/sermons)	PASS — added in Step 10
churchData.js used only as fallback skeleton	PASS — API overwrites on load
eventsUpdated event dispatched	PASS
sermonsUpdated event dispatched	PASS
SermonsSection listens to sermonsUpdated	PASS

12. Performance — PASS

Check	Result
All public APIs paginated	PASS
Hard max 100 items per page	PASS (tested)
Gallery uses Load More (20/page)	PASS
Gallery images use loading="lazy"	PASS
Hero images not lazy loaded	PASS
Database indexes (migration-04)	PASS (executed)
No unbounded select('*') without range()	PASS

13. Accessibility — WARNING

Check	Result
Contact form uses placeholder only (no <label for="">)	WARNING
Lightbox uses role="dialog" and aria-modal	PASS
Gallery items use role="button" and aria-label	PASS
Keyboard navigation	NOT TESTED (requires browser)
Form error messages announced to screen readers	NOT TESTED

14. SEO — PASS with WARNINGS

Check	Result
index.html title tag	PASS — "Centenary Baptist Church Est. 1875, Secunderabad"
Meta description	PASS
Dynamic route page titles	NOT FIXED — SPA hash routing does not update <title>
Open Graph metadata	NOT PRESENT — WARNING
robots.txt	NOT PRESENT — WARNING
sitemap.xml	NOT PRESENT — WARNING

15. Build & Deployment — PASS

npm run build →  SUCCESS

93 modules transformed in 563ms. Zero compilation errors. Zero secrets or localhost:3000 references in dist/.

16. Final Regression Audit

ID	Original Finding	Status
C-01	Homepage Events CMS disconnect	FIXED
C-02	Hardcoded localhost:3000 API URLs	FIXED
S-01	Unauthenticated CMS mutations	FIXED
S-02	Public Super Admin setup endpoint	FIXED
S-03	Secrets in .env not isolated	FIXED
S-04	CORS was wildcard *	FIXED
S-05	Unconstrained file uploads	FIXED
S-06	Date.now() as primary keys	FIXED
S-07	RLS not enabled	FIXED
S-08	Unauthenticated audit-log access	FIXED
S-09	Donation QR on local filesystem	PARTIALLY FIXED — QR re-upload pending
S-10	No API pagination	FIXED
S-11	CSP disabled	NOT FIXED — Intentional deferral
S-12	Missing SEO metadata	PARTIALLY FIXED — Title & description present; OG/robots missing

17. Production Readiness Decision

A. Security PASS	B. Database PASS
C. Backend/API PASS	D. Frontend PASS
E. Performance PASS	F. Accessibility WARNING
G. SEO WARNING	H. Deployment PASS WITH WARNINGS

J. Remaining Risks

- **CSP disabled** — XSS risk not mitigated by browser policy. Must be enabled before go-live.
- **donation_config write is "authenticated" not "super_admin"** — Low risk; Express middleware guards the route.
- **Bundle size 663KB** — Not a security risk but impacts LCP on slow mobile connections.
- **Dynamic page titles** — SPA hash routing does not update <title> on navigation. Impacts SEO for sub-pages.

K. Manual Actions Required Before Go-Live

#	Action	Where
1	Re-upload QR code image to migrate to Supabase Storage	Admin Dashboard → Donations
2	Set CORS_ORIGIN environment variable to production domain	.env (production) or hosting platform
3	Enable and configure CSP in server.js after auditing inline scripts	server.js → Helmet config

L. Final Checklist

✓ Authentication (JWT + Supabase)	✓ Authorization (requireAuth / requireSuperAdmin)
✓ Secret isolation (no keys in frontend bundle)	✓ RLS enabled on all tables
✓ setup-super-admin endpoint removed	✓ No hardcoded credentials
✓ File upload security (5MB, MIME, UUID)	✓ Donation config on Supabase (pending QR upload)
✓ Frontend API URLs clean (no localhost in dist/)	✓ API pagination (max 100 rows)
✓ Gallery Load More pagination	✓ Database indexes applied
✓ Build succeeds, no secrets in dist/	✓ CORS non-wildcard
⚠ CSP — disabled (must enable before go-live)	⚠ Open Graph / robots.txt / sitemap missing
⚠ Contact form accessibility labels	🔧 Donation QR — manual re-upload required
🔧 Production CORS_ORIGIN env variable	🔧 CSP configuration before public launch

✓ FINAL VERDICT: READY FOR PRODUCTION DEPLOYMENT

The application has passed all critical security remediations across Steps 1–12 of Phase 6. Complete the 3 manual actions above before go-live. No critical security issues remain unresolved.